

Guía Metodológica de la Encuesta de Madurez en Ciberseguridad (Modelo GCI-Empresa)

1. Objetivo de la encuesta

Esta encuesta tiene como objetivo evaluar la madurez de ciberseguridad de organizaciones públicas y privadas utilizando como marco de referencia los cinco pilares del Global Cybersecurity Index (GCI) de la UIT: legal, técnico, organizativo, desarrollo de capacidades y cooperación.[web:28][web:38]

El propósito no es “rankear” empresas, sino identificar brechas, orientar prioridades de inversión y generar información comparativa que pueda alimentar tanto decisiones internas como iniciativas sectoriales y nacionales (por ejemplo, en el contexto de España Digital 2026).[web:39]

2. Marco conceptual

- Global Cybersecurity Index (GCI)
- Índice compuesto que evalúa el compromiso de los estados con la ciberseguridad a partir de indicadores en cinco pilares, medidos mediante un cuestionario detallado (GCIv5: 83 preguntas, 20 indicadores, 64 sub-indicadores, 28 micro-indicadores).[web:33]
- Los indicadores se centran en la existencia y aplicación de marcos legales, capacidades técnicas, estructuras organizativas, desarrollo de capacidades y cooperación internacional.[web:28][web:38]
- Adaptación al ámbito empresarial
- La encuesta traslada estos pilares al nivel de organización, preguntando por estructuras internas, procesos, tecnología, talento y relaciones con terceros.
- El resultado se expresa en índices de madurez por pilar y una puntuación global de “compromiso y capacidad de ciberseguridad” a nivel empresa.

Los indicadores se centran en la existencia y aplicación de marcos legales, capacidades técnicas, estructuras organizativas, desarrollo de capacidades y cooperación internacional.[web:28][web:38]

Adaptación al ámbito empresarial

3. Diseño del cuestionario

3.1. Estructura

La encuesta está estructurada en siete bloques:

1. Datos generales de la organización
2. Pilar jurídico
3. Pilar técnico
4. Pilar organizativo
5. Pilar desarrollo de capacidades
6. Pilar cooperación
7. Inversión, ROI y percepción de riesgo

Cada bloque contiene preguntas cerradas (respuesta múltiple) y algunas preguntas abiertas para capturar matices cualitativos.

3.2. Escalas de respuesta

- Predominan escalas ordinales de 3–5 niveles que permiten mapear el grado de madurez (de “inexistente” a “avanzado”).
- Se privilegia la respuesta autoevaluativa con descriptores claros para reducir la ambigüedad (por ejemplo, “documentado”, “probado”, “monitorizado”).
- El diseño se inspira en cuestionarios de madurez existentes (GCI, herramientas ENISA para pymes, encuestas industriales).[web:35][web:40][web:41]

3.3. Duración y logística

- Tiempo estimado de respuesta: 25–35 minutos (similar a herramientas de madurez ENISA).[web:35]
- Recomendado que la responda una persona con visión transversal (CISO, CIO, responsable de riesgos) con apoyo de otras áreas si es necesario.
- Formato sugerido: versión digital (web o formulario) con posibilidad de guardar y continuar.

4. Población objetivo y muestreo

4.1. Población objetivo

- Organizaciones públicas y privadas con actividad significativa en España, especialmente:
- Operadores de servicios esenciales y entidades sujetas a NIS2 / ENS.
- Empresas medianas y grandes en sectores críticos (energía, salud, finanzas, transporte, TIC).
- Pymes con alto grado de digitalización (en línea con los objetivos de España Digital 2026).[web:39]

4.2. Estrategia de muestreo

- Muestreo estratificado por:
- Sector de actividad.
- Tamaño de empresa.
- Naturaleza pública / privada.
- Objetivo: muestras mínimas por estrato que permitan análisis comparativos (idealmente ≥ 30 respuestas por estrato clave).

5. Construcción de índices de madurez

5.1. Ponderación básica

8. Asignar a cada opción de respuesta un valor numérico (por ejemplo, 0–4).
9. Agrupar las preguntas por pilar GCI:
10. Legal
11. Técnico
12. Organizativo
13. Desarrollo de capacidades
14. Cooperación
15. Calcular, para cada organización:
16. Puntuación por pilar = media (o suma normalizada) de las respuestas asociadas.
17. Puntuación global = media ponderada de los cinco pilares.

Cooperación

Calcular, para cada organización:

Se recomienda comenzar con ponderaciones iguales por pilar y ajustar tras análisis empírico (por ejemplo, mediante análisis factorial o consultas a un panel de expertos).

5.2. Niveles de madurez

Definir niveles de madurez por pilar inspirados en esquemas de 4–5 niveles:

- Nivel 0 – Inexistente
- Nivel 1 – Inicial / ad hoc
- Nivel 2 – Definido
- Nivel 3 – Gestionado
- Nivel 4 – Optimizado

Cada rango de puntuación se mapea a un nivel, permitiendo generar perfiles tipo “Pilar técnico en nivel 3, pilar de capacidades en nivel 1”.

6. Análisis de resultados

6.1. Análisis descriptivo

- Distribución de niveles de madurez por pilar y sector.
- Comparación entre tamaños de empresa.
- Identificación de pilares “fuertes” y “débiles” por segmento.

6.2. Análisis comparativo y benchmarking

- Construcción de gráficos radar por empresa / sector para visualizar diferencias entre pilares.
- Comparación con metas alineadas con políticas nacionales (ej. objetivos de España Digital 2026 en ciberseguridad).[web:39]

6.3. ROI y correlaciones

- Relacionar la madurez por pilar con:
- Nivel de inversión en ciberseguridad (porcentaje del presupuesto TI).
- Número de incidentes significativos (si se recoge en ampliaciones de la encuesta).
- Percepción de preparación ante amenazas (auto-evaluación).

7. Ética, confidencialidad y uso de datos

- Garantizar anonimato o seudonimización en el tratamiento de respuestas.
- Informar a los participantes del uso de los resultados (informes agregados, benchmarks, recomendaciones).
- Evitar el uso de los datos para fines punitivos o estrictamente comerciales; privilegiar el enfoque de mejora continua.

8. Actualización del instrumento

La encuesta debe revisarse, al menos, cada dos años para:

- Alinearla con nuevas versiones del GCI y sus indicadores.[web:33]
- Incorporar cambios regulatorios (NIS2, ENS, DORA, normativa sectorial).
- Introducir nuevos dominios (IA, OT, cadena de suministro) según la evolución del panorama de amenazas y las prácticas de referencia.[web:40][web:41]